

Security Essentials

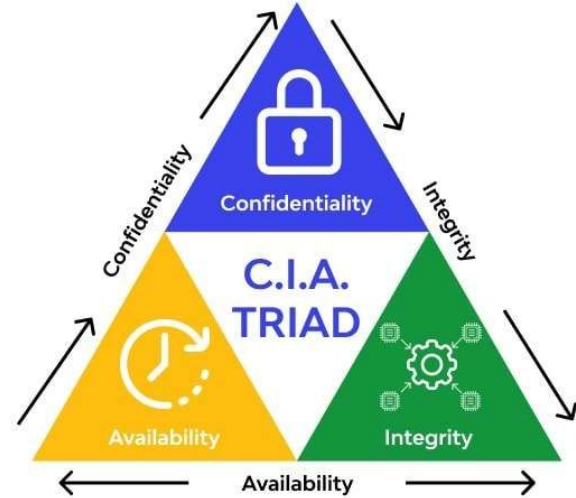
System Design Crash Course: Quick Revision Before Interviews

Rahul Rajat Singh



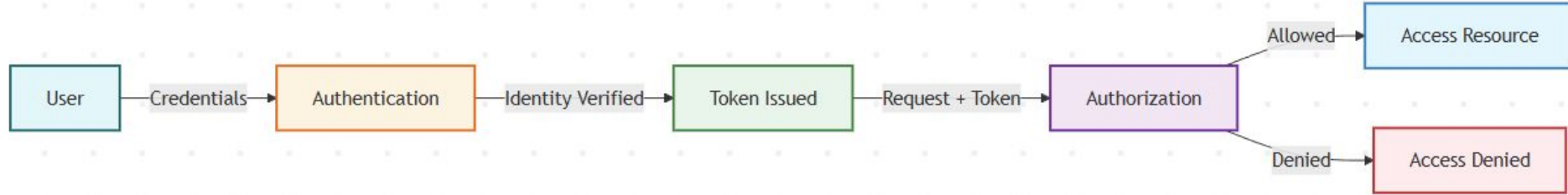
CIA Triad

- Confidentiality: who can access data
- Integrity: data correctness and trust
- Availability: system uptime and access
- Improving one weakens others
- Security decisions map to CIA



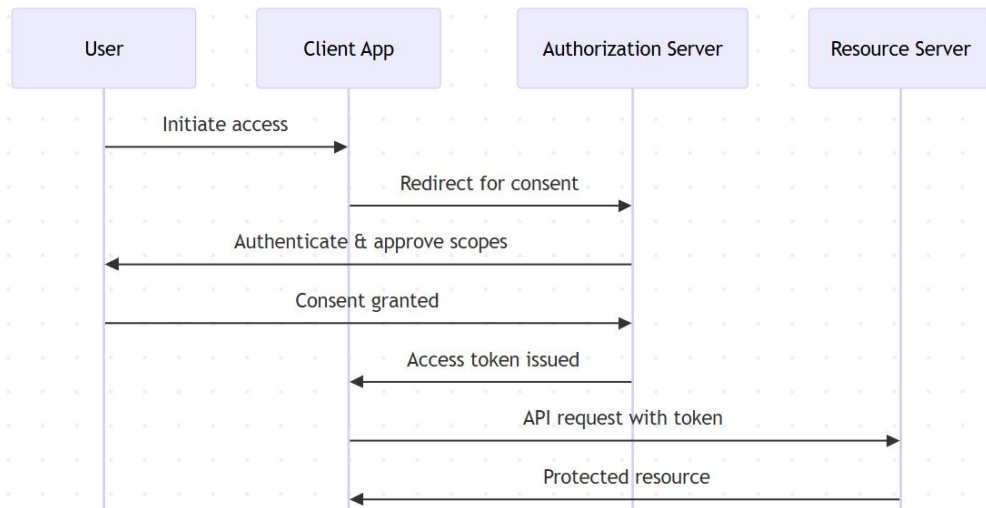
Authentication vs Authorization

- Authentication: who are you
- Authorization: what can you do
- AuthN happens before AuthZ
- Tokens enable authorization
- Often confused, rarely interchangeable



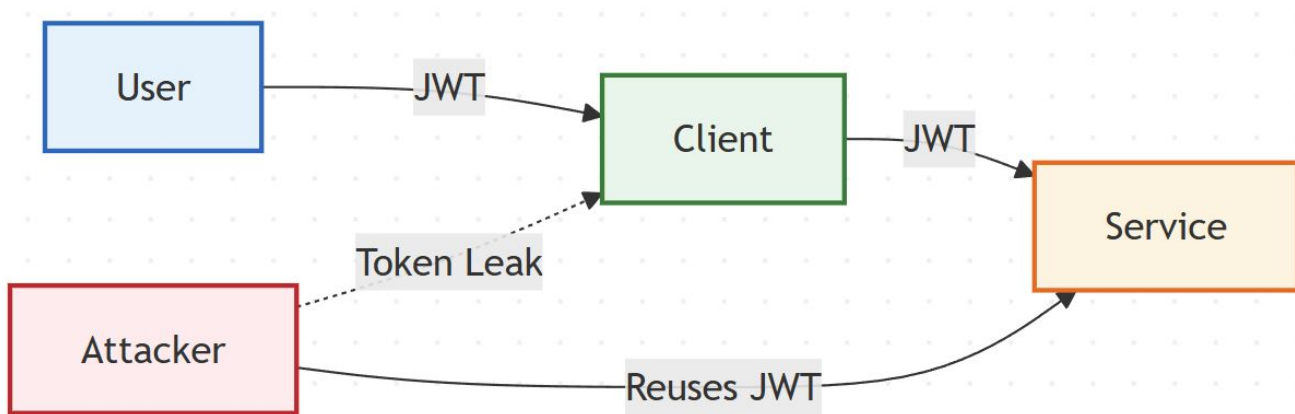
OAuth 2.0 Basics

- Delegated access without password sharing
- Roles: client, user, authorization server
- Access tokens represent granted permissions
- Scopes limit what client can do
- Authorization, not authentication protocol



JWT Security Pitfalls

- Long-lived tokens increase blast radius
- Tokens are bearer credentials
- No server-side revocation by default
- Overstuffed claims leak sensitive data
- JWTs are not encrypted



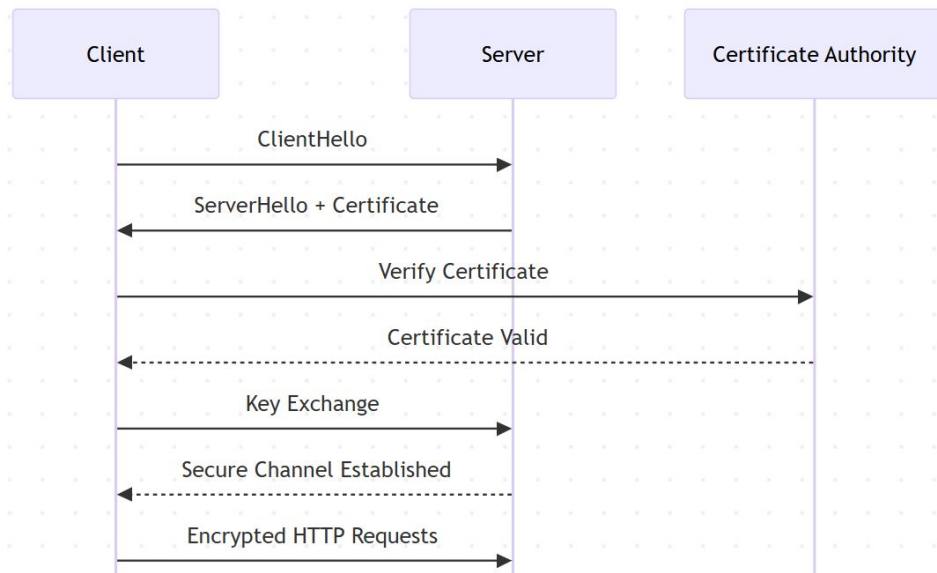
Encryption at Rest vs In Transit

- At rest: stored data encrypted
- In transit: data encrypted over network
- Different threats, different controls
- TLS vs disk/database encryption
- Compliance often requires both



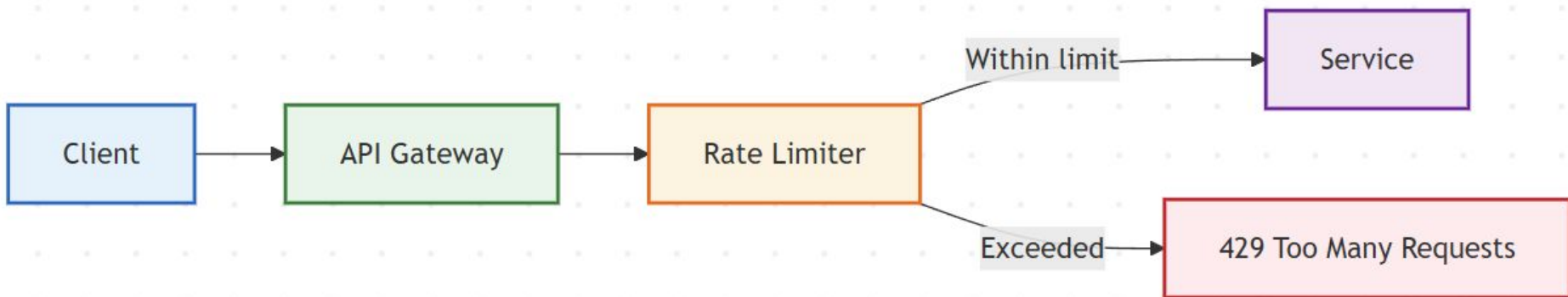
TLS and HTTPS

- TLS secures communication channel
- HTTPS = HTTP over TLS
- Encrypts, authenticates, ensures integrity
- Certificates prevent impersonation
- Adds latency, enables trust



Rate Limiting

- Limits requests per client
- Protects from abuse, overload
- Fixed, sliding, token bucket
- Applied per IP, user, key
- Trade-off: fairness vs throughput



DDoS Basics

- Overwhelming traffic exhausts resources
- Volumetric, protocol, application attacks
- Distributed sources hide attackers
- Mitigation requires layered defenses
- Trade-off: cost vs protection



OWASP Top 10 Awareness

- List of common web vulnerabilities
- Focus on risk, not exploits
- Covers auth, data, config flaws
- Updated periodically by community
- Awareness beats memorization

